

DATA MINING & MACHINE LEARNING

PhishingSphere

Data Mining & Machine Learning Project

M.Sc. in Artificial Intelligence and Data Engineering — Academic Year 2025–2026

[Mattia Correnti — ID: 665367] | [Francesco Ladu — ID: 722538]

[16/09/2026]

Presentation Outline

01

Problem & Dataset

Task definition · features · EDA

02

Pipeline & Experiments

Preprocessing · model selection · hyperparameter optimization

03

Evaluation & Results

Metrics · cross-validation · final model performance

04

Explainability

Global & local techniques · consistency with domain knowledge

05

Critical Discussion

Error analysis · limitations · future directions

PART 1

PART 2

PART 1 — TECHNICAL

Problem, Pipeline & Results

Problem definition · feature engineering · model selection
hyperparameter optimization · evaluation · test-set results

Problem Definition & Dataset

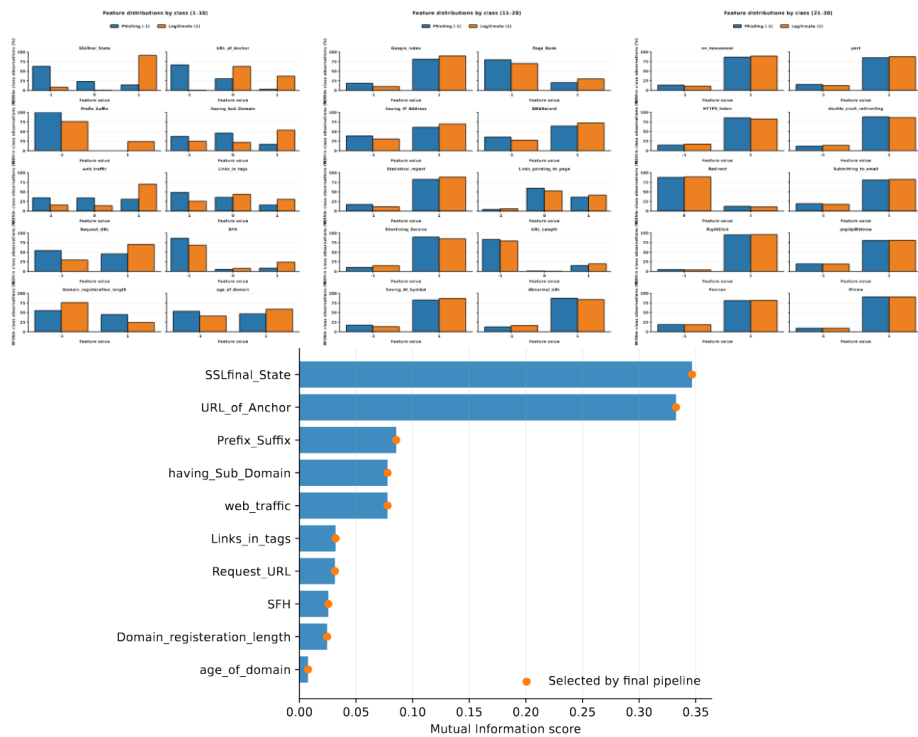
The Problem

- Detect whether a website is phishing or legitimate from URL, HTML/JavaScript, domain, and reputation signals
- Binary classification: Result = -1 for phishing, +1 for legitimate
- False negatives are critical because phishing websites remain undetected
- False positives may block legitimate services.
- Repeated and conflicting predictor profiles can make evaluation too optimistic if ignored.

Dataset at a Glance

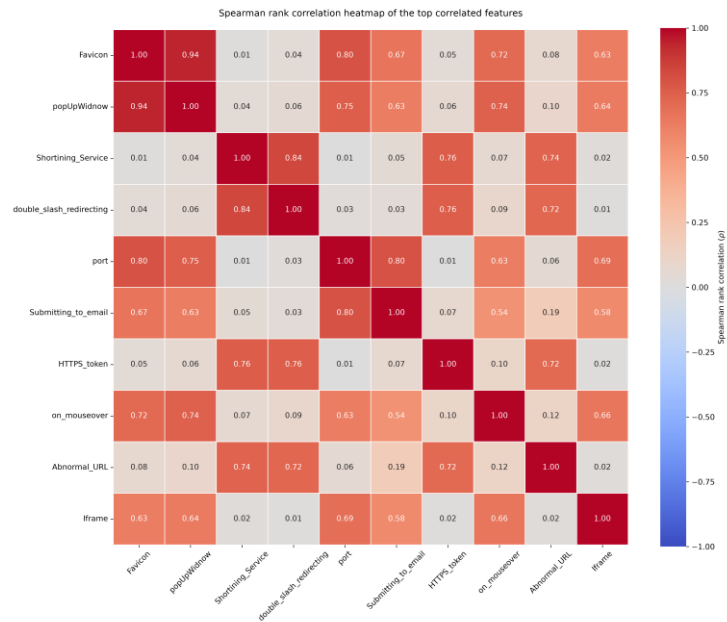
Task	Binary classification
Dataset	UCI Phishing Websites: 11,055 observations
Target	Result $\in \{-1, +1\}$
Features	30 discrete or ordinal predictors
Missing values	None
Class balance	44.31% phishing – 55.69%
Split	20% held-out test/ 80% development
Metric(s)	Accuracy, F1-macro, precision, recall, ROC-AUC

Exploratory Data Analysis



Key findings from EDA:

The dataset is balanced (44.3% vs 55.7%) with 0% missing values; SSLfinal_State (0.347) and URL_of_Anchor (0.333) show highest Mutual Information, high collinearity exists among visual/networks features (e.g. $\rho = 0.940$), 57 conflicting profiles involving 270/8,844 development observations (3.05%).



Feature Engineering & Selection

Engineering

- No manual transformation/scaling needed: attributes are pre-discretized discrete integer codes in $\{-1, 0, 1\}$
- **Duplicate Treatment:**
 - Exp 1 (raw): 11,055 rows
 - Exp 2 (exact deduplication): 5,849 rows
 - Exp 3 (weighted deduplication): 5,772 profiles

Selection Method

- Filter method using **Mutual Information** (*SelectKBest*), jointly tuned across $k \in \{5, 10, 15, 20, 25, \text{all}\}$
- Strictly fitted within inner training folds to eliminate validation leakage
- Final pipeline in Exp 3 selected $k = \text{all}$ (30 features); Exp 2 selected $k = 25$

Why These Features?

- Phishing detection requires complementary multi-source signals (URL tokens, SSL status, iframe/popup structure, WHOIS age, DNS records)
- Discarding lower-ranked features in Exp 2 (popUpWindow, RightClick, on_mouseover, Iframe, Submitting_to_email) slightly reduced generalization;

ML Pipeline: Avoiding Data Leakage & Bias



Data Leakage Prevention

- **Nested Stratified CV:** 10 outer folds for generalization estimation; 5 inner folds for hyperparameter tuning and feature selection
- Held-out test set (20%) remained completely untouched until final evaluation

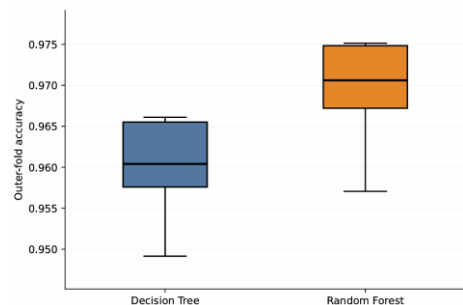
Class Imbalance Handling

- Naturally balanced target (44.3% vs 55.7%), eliminating the need for synthetic oversampling
- Retained-support sample weights applied strictly during fitting and scoring inside training folds
- Macro F1 and ROC-AUC were reported alongside accuracy to assess class-wise performance and ranking quality.

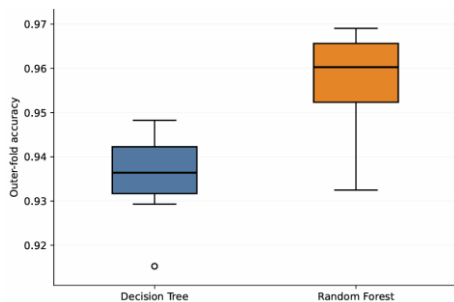
Metric Justification

- Primary: Exp. 1-2: accuracy; Exp. 3: retained-support weighted accuracy; measures overall operational correctness
- **Secondary:**
 - Phishing Recall: Essential to minimize missed phishing attacks (False Negatives)
 - Phishing Precision: Minimize false alarms on legitimate domains
 - Macro F1 & ROC-AUC: Balances both classes independently of threshold choice

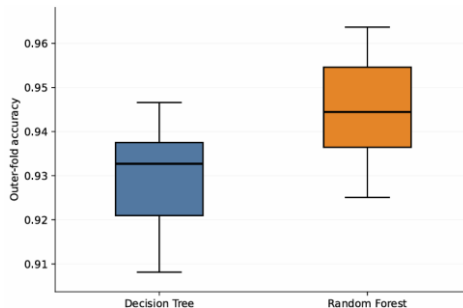
Model Selection & Hyperparameter Optimization



Outer-fold Accuracy: Exp 1 & 2



Outer-fold Accuracy: Exp 3

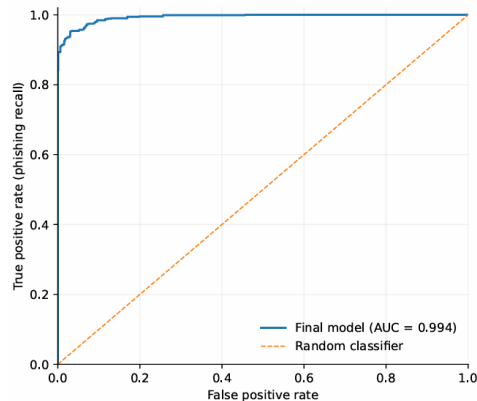
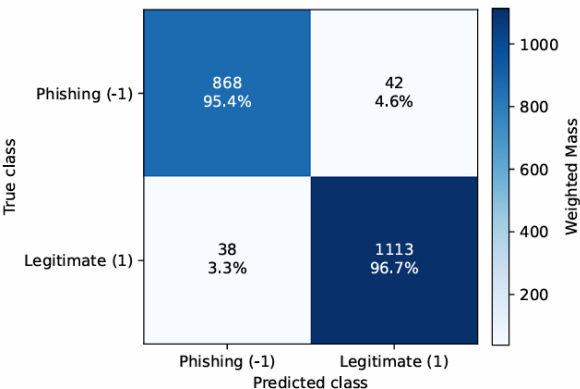


Key Decisions

Candidate models	Decision Tree (baseline) vs Random Forest (variance reduction)
CV strategy	Nested Stratified CV (10 outer folds x 5 inner folds)
Selection criterion	Retained-support weighted accuracy (Exp 3) with 1-SE rule
Chosen model	Random Forest (significantly outperformed DT across all 3 experiments)
Search strategy	DT: Grid Search; RF: Randomized Search (180 configurations)
Search space	$k \in \{5 \dots 30\}$, $n_estimators$ (100-800), max_depth (None, 5-30), $min_samples_split$ (2-10), $bootstrap$
Best config	$k = all$, $n_estimators = 600$, $criterion = gini$, $max_depth = 20$, $min_samples_split = 6$, $min_samples_leaf = 1$, $max_features = log2$, $bootstrap = False$
Statistical test	Two-sided Wilcoxon signed-rank test on 10 outer folds: $W = 1$, $p = 0.00391$ (mean improvement +0.0219)

RESULTS

Test-Set Results



Model	HP tuning	CV strategy	Val. metric	Test metric
DT / Exp. 1	Grid Search	Nested 10/5-fold	0.9604	0.9711
RF / Exp. 1	Random Search	Nested 10/5-fold	0.9699	0.9760
DT / Exp. 2	Grid Search	Nested 10/5-fold	0.9299	0.9368
RF / Exp. 2	Random Search	Nested 10/5-fold	0.9455	0.9487
DT / Exp. 3	Grid Search	Nested 10/5-fold	0.9359	0.9360
RF / Exp. 3	Random Search	Nested 10/5-fold	0.9578	0.9612

Key Metrics (Test Set)

96.12%

Weighted Test Accuracy

96.06%

Macro F1-Score

95.38/95.81%

Phishing Recall/Precision

99.37%

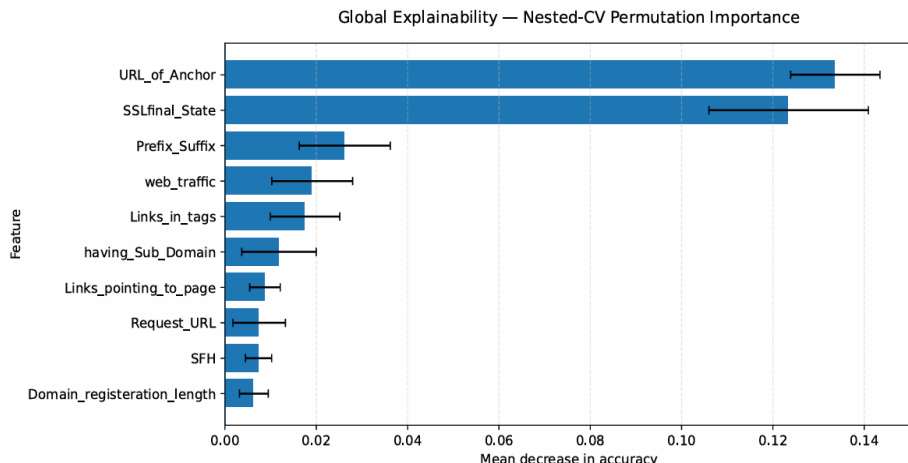
ROC-AUC

PART 2 — CRITICAL ANALYSIS

Explainability & Critical Discussion

How does the model work? · What did it get wrong and why?
Limitations · future directions · domain impact

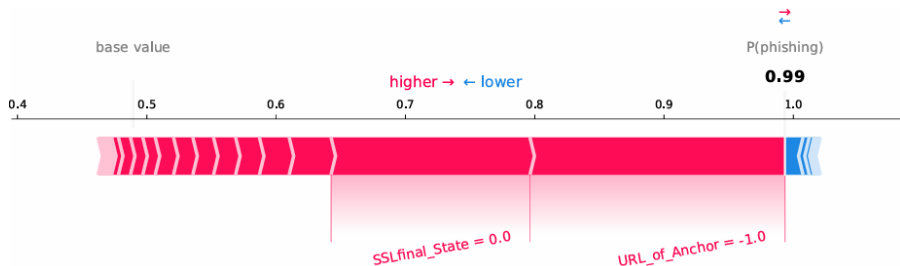
Global Explainability: What Drives the Model Overall?



Interpretation

- Outer-fold Permutation Importance (computes mean accuracy decrease on unseen validation folds)
- URL_of_Anchor and SSLfinal_State are the top two global features, aligning directly with initial EDA mutual information findings
- Phishing attacks heavily rely on deceptive anchor hyperlinks (pointing to external or empty targets) and forged/untrusted SSL certificates
- Secondary features (Prefix_Suffix, web_traffic, having_Sub_Domain, Links_in_tags) ensure the model bases on diverse signals rather than a single bypassable indicator

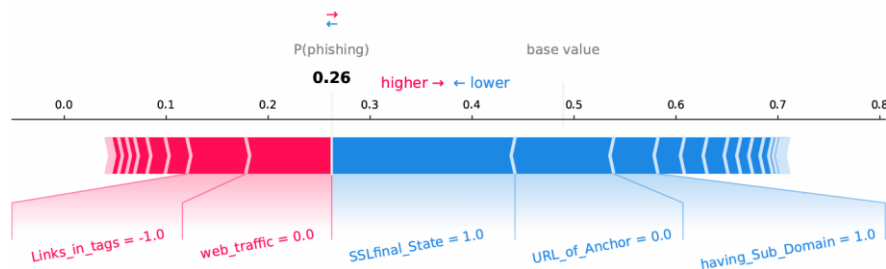
Local Explainability: Why This Specific Prediction?



Case Analysis:

- Correctly classified phishing example — **true label: phishing**
- TreeSHAP decomposition showing additive contributions pushing predicted probability from base value to output
- URL_of_Anchor = -1 (suspicious/external anchor links) and SSLfinal_State = 0 (untrusted/missing SSL) strongly pushed toward phishing
- The top local SHAP push factors match the top two predictors identified in global permutation importance
- Phishers can easily clone page visual assets, but struggle to force legitimate SSL hierarchies and authentic internal link structures
- While true cases show aligned indicators, misclassifications occur when attackers acquire valid SSL certificates (SSLfinal_State = 1, 96 OOF errors) or when anchors are neutral (URL_of_Anchor = 0, 8.19% error)

Error Analysis: What Did the Model Get Wrong and Why?



Reverse-Engineering Errors

- False negative, **true: phishing, predicted: legitimate**
- 44 unique test profiles misclassified (26 FN, 18 FP), representing a weighted error mass of 80 out of 2061 observation (42 FN, 38 FP)
- Errors concentrate heavily on neutral/intermediate feature values: `web_traffic = 0` (8.44% error) and `URL_of_Anchor = 0` (8.19% error vs 0.34% for -1)
- 96 out-of-fold FN occurred when `SSLfinal_State = 1`, showing that phishers using legitimate free SSL certificates bypass simple connection checks
- 57 profiles in the dataset share identical feature vectors with conflicting ground-truth labels, establishing an irreducible floor for 30 discrete attributes

Literature Comparison: Shabudin et al. (2020) [1] evaluated Random Forest on the same UCI Phishing Websites dataset using 10-fold CV, feature selection and hyperparameter tuning, obtaining 97.18% accuracy. Our RF achieved 97.60% on the raw representation (Exp. 1) and 96.12% under weighted profile deduplication (Exp. 3). Our evaluation additionally uses a held-out test set and nested 10×5 CV for model selection.

Domain Impact, Limitations & Future Directions

Domain Impact

- Automated first-line phishing filter for browser extensions and corporate email/web security gateways
- False negatives leave phishing sites undetected; false positives may incorrectly block legitimate services
- Final model achieved **95.38% phishing recall**; high-confidence predictions could support automated triage, with human review for uncertain cases

Limitations

- Historical UCI dataset may not represent modern phishing tactics
- Pre-discretized $\{-1, 0, 1\}$ features discard raw URLs, webpage text, DOM structure, and visual information
- Identical 30-feature profiles can have conflicting labels, indicating intrinsic representation ambiguity
- Evaluation is limited to a single dataset

Future Directions

- Validate on recent, temporally separated phishing data to assess temporal drift and external generalization
- Add raw URL, HTML/DOM, textual, and screenshot-based information
- Explore URL, DOM, and vision-based models on richer representations
- Calibrate probabilities and optimize decision thresholds according to FN/FP operational costs

Thank You

Conclusions:

- Phishing detection was evaluated on the UCI dataset under three treatments of repeated predictor profiles.
- Random Forest was selected over Decision Tree through nested stratified 10×5 CV; Exp. 3 was used for the final analysis.
- URL_of_Anchor and SSLfinal_State were the main global drivers, while errors concentrated on ambiguous and conflicting profiles.
- The main limitation is the historical, pre-discretized dataset; future work should evaluate recent temporally separated data with richer feature representations

Mattia Correnti · m.correnti@studenti.unipi.it

Francesco Ladu · f.ladu1@studenti.unipi.it